PR02-01: EL ESLABÓN MÁS DÉBIL: DISEÑO ÉTICO DE UNA CAMPAÑA DE INGENIERÍA SOCIAL.

Investigación comparativa de plataformas

CNO V – Seguridad Informática

PARCIAL II: TÉCNICAS DE EXPLOTACIÓN DE VULNERABILIDADES Y SEGURIDAD EN ENTORNOS TECNOLÓGICOS.

Mtro. Servando López Contreras

Omar Karim Alonso Castillo

Universidad Politécnica de San Luis Potosí

Contenido

Introducción 2
Objetivo General 2
Objetivos Específicos 2
Marco Teórico y Fundamentación Técnica 3
Click Rate (Tasa de Clics) 3
Reporting Rate (Tasa de Reporte): 3
Risk Score (Puntuación de Riesgo): 3
Minería de Datos Comportamentales y Modelado de Riesgo 3
Principios Psicológicos de la Ingeniería Social (Vectores de Influencia) 4
Diversificación de Vectores de Ataque (Multicanalidad) 4
Análisis Individual de Plataformas 5
Hoxhunt 5
Proofpoint (Security Awareness Training) 6
KnowBe4 6
Cofense (PhishMe) 6
Phished 6
NINJIO 6
Mimecast (Awareness Training) 7
Infosec IQ 7
Análisis Crítico y Conclusiones 10
Referencias 11

Introducción

La gestión del riesgo humano constituye una dimensión crítica en la arquitectura de seguridad de cualquier organización tecnológica. Ante la sofisticación de los ataques de ingeniería social, que logran eludir controles perimetrales complejos, la industria ha evolucionado desde los modelos tradicionales de concienciación teórica hacia sistemas dinámicos de medición y mitigación de vulnerabilidades cognitivas. Este documento presenta un análisis profundo y estructurado de ocho plataformas líderes en simulación de phishing, evaluando sus métricas de telemetría, arquitecturas pedagógicas, capacidades de integración técnica y la rigurosidad ética aplicada a la formación de los usuarios.

Objetivo General

Realizar un análisis comparativo de plataformas profesionales del mercado, con el propósito de medir el nivel de reconocimiento de amenazas de ingeniería social en usuarios y fortalecer la postura de seguridad organizacional.

Objetivos Específicos

- Analizar y comparar de manera individual 8 plataformas de simulación de phishing (Hoxhunt, Proofpoint, KnowBe4, Cofense, Phished, NINJIO, Mimecast e Infosec IQ).
- Identificar y contrastar sus capacidades técnicas, integraciones y limitaciones operativas.
- Evaluar las métricas de medición utilizadas, los enfoques de entrenamiento de los usuarios y los controles éticos aplicados en la gestión del riesgo humano.

Marco Teórico y Fundamentación Técnica

Para evaluar la efectividad de estas plataformas, es indispensable comprender la evolución de las métricas clave y los enfoques técnicos que rigen la industria.

Click Rate (Tasa de Clics)

Mide la susceptibilidad. Es el porcentaje de usuarios que interactúan negativamente con una simulación. Aunque históricamente fue la métrica principal, hoy se considera insuficiente por sí sola, ya que un click rate bajo no implica necesariamente una defensa activa.

Reporting Rate (Tasa de Reporte):

Mide la resiliencia. Es el porcentaje de usuarios que utilizan el botón de reporte (ej. Phish Alert Button) al detectar una amenaza. Una tasa alta de reporte convierte a los empleados en una red de sensores de amenazas reales.

Risk Score (Puntuación de Riesgo):

Una métrica compuesta que cuantifica el nivel de riesgo de un usuario, departamento o la organización entera. Se calcula combinando el comportamiento en simulaciones, el cumplimiento de capacitaciones, el rol del usuario, y las integraciones con el ecosistema de seguridad (Identity and Access Management, Endpoints).

Minería de Datos Comportamentales y Modelado de Riesgo

En el contexto de la gestión del riesgo humano, el cálculo del nivel de vulnerabilidad (*Risk Score*) trasciende la simple tabulación de clics en campañas simuladas. Las plataformas modernas de concienciación implementan técnicas avanzadas de minería de datos sobre la telemetría generada por los usuarios. Esto implica la extracción de patrones ocultos en grandes volúmenes de datos transaccionales, evaluando variables críticas como la frecuencia de conexión, los tiempos de latencia entre la apertura de un correo y la ejecución de una acción (ya sea la interacción con el enlace malicioso o la activación del botón de reporte), y el contexto del dispositivo utilizado.

Mediante la aplicación de algoritmos predictivos y, en las arquitecturas más avanzadas, el uso de redes neuronales para el procesamiento de estas series temporales, los sistemas logran clasificar a los usuarios y modelar el riesgo probabilístico de manera dinámica. Este enfoque analítico permite identificar qué perfiles o departamentos presentan mayor susceptibilidad ante vectores de ataque específicos, facilitando una mitigación proactiva y el despliegue de políticas de seguridad basadas en evidencia estadística sólida, en lugar de suposiciones estáticas.

Principios Psicológicos de la Ingeniería Social (Vectores de Influencia)

La ingeniería social no explota vulnerabilidades en el código o en la configuración de la infraestructura, sino sesgos cognitivos en el procesamiento de información del usuario final. Para que una plataforma de simulación sea técnicamente válida y formativa, debe replicar con precisión los vectores de influencia psicológica documentados en la literatura empírica. Los ciberdelincuentes diseñan sus cargas útiles (*payloads*) semánticas basándose en heurísticos fundamentales:

- **Urgencia y Escasez:** Se emplean narrativas como la expiración inminente de credenciales o la cancelación de servicios para provocar un estado de alerta en el usuario, forzando una toma de decisiones rápida que interrumpe el análisis crítico del mensaje.
- **Autoridad:** Consiste en la suplantación de entidades de alto nivel jerárquico (directivos, soporte de TI o instituciones gubernamentales) para inducir sumisión y obediencia automática frente a una instrucción.
- **Curiosidad o Recompensa:** Se utilizan cebos relacionados con beneficios económicos, ajustes salariales o información corporativa confidencial, explotando el interés personal para motivar la apertura de archivos adjuntos.

Comprender y medir la respuesta ante estos estímulos es crucial, ya que el objetivo del atacante es "hackear" la reacción emocional del usuario para lograr que este eluda voluntariamente los controles perimetrales de la organización.

Diversificación de Vectores de Ataque (Multicanalidad)

La evolución de la topología de redes corporativas y la ubicuidad de los dispositivos móviles han obligado a los actores de amenazas a diversificar sus métodos de intrusión más allá del correo

electrónico corporativo. Un marco integral de concienciación en ciberseguridad debe contemplar la multicanalidad de los ataques modernos, los cuales frecuentemente están diseñados para evadir túneles de comunicación seguros (como conexiones VPN *Site-to-Site* o de acceso remoto) y puertas de enlace de correo electrónico, dirigiendo la amenaza directamente hacia los endpoints personales o canales no monitorizados.

Entre los vectores emergentes de mayor impacto destacan:

- **Smishing (SMS Phishing):** Ejecución de ataques mediante mensajes de texto cortos que incluyen enlaces fraudulentos. Este vector explota la inmediatez de la lectura y la confianza inherente que los usuarios suelen depositar en la mensajería móvil, donde los filtros de *spam* son considerablemente menos robustos.
- **Vishing (Voice Phishing):** Fraudes telefónicos donde el atacante interactúa en tiempo real con la víctima. Impulsado actualmente por tecnologías de clonación de voz, busca extraer credenciales críticas, tokens de autenticación multifactor (MFA) o inducir transferencias no autorizadas.
- **Quishing (QR Phishing):** Integración de códigos QR maliciosos en documentos físicos, presentaciones o correos electrónicos aparentes. Su objetivo técnico es forzar al usuario a escanear el código con su teléfono inteligente, trasladando efectivamente la sesión de ataque fuera del entorno corporativo securizado y hacia una red externa sobre la cual la organización carece de visibilidad y control.

Análisis Individual de Plataformas

Hoxhunt

Se distingue por un enfoque de gamificación impulsado por inteligencia artificial. Su arquitectura se aleja del modelo punitivo y utiliza algoritmos de aprendizaje automático para hiper-personalizar los señuelos según la curva de aprendizaje de cada usuario. Técnicamente, destaca por su integración a nivel API con plataformas como Microsoft 365, automatizando la distribución de ataques simulados contextuales.

Proofpoint (Security Awareness Training)

Fundamenta su valor en la inteligencia de amenazas orientada a las personas. Su principal ventaja técnica radica en la utilización de campañas basadas en ataques reales detectados por sus propias pasarelas de correo, clasificando a los individuos como objetivos altamente atacados (VAPs). Su integración con herramientas de respuesta a incidentes permite una mitigación automatizada eficaz.

KnowBe4

Lidera el mercado mediante el volumen masivo de contenido y el enfoque en el cumplimiento normativo. Su inmensa biblioteca de plantillas y módulos interactivos proporciona gran flexibilidad, mientras que su herramienta PhishER permite a los centros de operaciones de seguridad gestionar los reportes de los usuarios. Sin embargo, requiere una carga administrativa considerable para configurar campañas complejas manualmente.

Cofense (PhishMe)

Opera bajo la filosofía de la defensa colaborativa, integrando fuertemente la inteligencia de fuentes abiertas y cerradas. La plataforma está diseñada para convertir a los empleados en sensores activos, canalizando rápidamente los reportes hacia plataformas de orquestación y automatización (SOAR) para analizar y mitigar amenazas reales en cuestión de minutos.

Phished

Ofrece una solución de automatización total basada en algoritmos predictivos. Diseñada para minimizar la intervención humana, la plataforma crea perfiles psicológicos de los usuarios utilizando datos de fuentes abiertas (OSINT) y programa campañas de phishing adaptativas. Esto resulta ideal para equipos con recursos de administración limitados.

NINJIO

Aborda la concienciación mediante la retención de la atención a través del microaprendizaje y la narrativa emocional. Utiliza episodios animados basados en brechas de seguridad reales de empresas reconocidas, operando bajo la premisa de que la conexión emocional con una historia incrementa drásticamente la retención del conocimiento técnico a largo plazo.

Mimecast (Awareness Training)

Integra el humor en su metodología pedagógica a través de módulos de video cortos, lo que reduce la fricción y la ansiedad del usuario frente a los equipos de soporte. Su fortaleza técnica definitiva es la integración nativa con su propia pasarela segura de correo electrónico, centralizando la gestión del riesgo de la red y la formación en una única consola.

Infosec IQ

Destaca por su flexibilidad y estricto mapeo de cumplimiento para normativas como NIST e ISO. La plataforma proporciona entrenamientos interactivos personalizables y cuadros de mando altamente detallados, siendo la opción preferida para organizaciones que requieren auditorías rigurosas y segmentación del riesgo por departamento.

Plataforma	Analítica y Métricas (Risk Score / Reporting)	Integración Técnica	Enfoque Ético y Cultural	Limitaciones Principales
Hoxhunt	Excelente tasa de reporte; *risk score* basado en IA evolutiva.	API M365/G-Workspace. Reducción de carga en SOC.	Muy alto. Fomenta refuerzo positivo y gamificación (estrellas/tablas de líderes).	Puede resultar costoso para PyMEs. Requiere cambio cultural fuerte.
Proofpoint	*Risk score* complejo atado a vulnerabilidad y nivel de ataque (VAPs).	Nativa con ecosistema Proofpoint (Clear, TRAP, TAP).	Moderado-Alto. Orientado al riesgo, evita señuelos engañosos traumáticos.	Interfaz curva de aprendizaje pronunciada. Requiere ecosistema propio para brillar.
KnowBe4	Métricas profundas. *Click rate*, *Phish-prone percentage*, *reporting rate*.	Active Directory, LMS (SCORM), SOAR vía PhishER.	Moderado. Depende de cómo el administrador configure las campañas.	Sobrecarga administrativa ("Fatiga de opciones"). Interfaz algo anticuada.
Cofense	Analítica centrada en velocidad de reporte y mitigación de falsos positivos.	Excelente con herramientas SIEM/SOAR y respuesta a incidentes.	Alto. Enfocado en el usuario como defensa, no como problema.	El contenido de entrenamiento (videos) no es tan robusto como el de sus rivales.
Phished	Métricas generadas automáticamente. Previsión de riesgo IA.	Integración con AD, Google Workspace y herramientas de RRHH.	Alto. Entrenamientos adaptativos y no invasivos.	Falta de granularidad para administradores que desean control total manual.

NINJIO	Mide engagement, visualizaciones y puntuación de riesgo actitudinal.	Integraciones estándar con LMS e Identity Providers (IdP).	Alto. Promueve la empatía a través de historias reales dramatizadas.	Limitado en la sofisticación técnica de los ataques simulados.
Mimecast	Riesgo de empleado integrado al riesgo general del correo (Mimecast SAFE).	Nativa 100% con su propio Secure Email Gateway.	Alto. El uso del humor reduce el estrés y la fricción con TI.	Limitado si la organización utiliza un proveedor de correo/gateway distinto.
Infosec IQ	Métricas altamente orientadas al cumplimiento y auditoría técnica.	SSO, AD, y soporte para exportar datos a plataformas BI.	Moderado-Alto. Permite adaptar campañas a políticas de RRHH.	Automatización menos avanzada en comparación con plataformas "Zero-Touch" o IA pura.

Análisis Crítico y Conclusiones

El análisis de la oferta actual evidencia una polarización tecnológica en el mercado: por un lado, arquitecturas impulsadas por redes neuronales y automatización total, y por otro, soluciones fundamentadas en repositorios masivos de inteligencia de amenazas y cumplimiento normativo. Para infraestructuras empresariales con centros de operaciones maduros que buscan integrar la telemetría del usuario con la respuesta a incidentes y flujos de trabajo ITIL, Proofpoint y Cofense ofrecen las arquitecturas más sólidas. Por el contrario, si la prioridad es auditar el cumplimiento normativo mediante métricas tradicionales, KnowBe4 e Infosec IQ se posicionan como líderes por su capacidad de segmentación.

No obstante, en entornos donde se busca mitigar el eslabón humano interviniendo directamente en el comportamiento sin generar fricción operativa, Hoxhunt y NINJIO sobresalen en el aspecto técnica. La conclusión técnica fundamental de este análisis es el declive de la tasa de clics como indicador de éxito aislado. Las organizaciones de tecnologías de la información deben priorizar plataformas que calculen el riesgo mediante algoritmos dinámicos y fomenten una alta tasa de reporte, equilibrando la sofisticación técnica de la simulación con un marco ético que consolide al usuario final como una extensión activa del perímetro de seguridad.

Referencias bibliográficas

- AXELOS. (2019). *ITIL foundation: ITIL 4 edition*. TSO (The Stationery Office).
- Cialdini, R. B. (2021). *Influence, new and expanded: The psychology of persuasion*. Harper Business.
- Cofense. (2023). *The state of phishing intelligence: How active threat detection empowers end users*.
- Hoxhunt. (2023). *Behavioral cybersecurity: Moving beyond traditional security awareness training*.
- Infosec. (2023). *Security awareness and training: A guide to compliance and human risk management*.
- KnowBe4. (2024). *Comprehensive guide to security awareness training and simulated phishing*.
- Mimecast. (2023). *The state of email security report 2023*.
- NINJIO. (2023). *The science of storytelling and microlearning in cybersecurity awareness*.
- Phished. (2023). *AI-driven human risk management: Automating phishing simulations and behavioral analysis*.
- Proofpoint. (2024). *State of the phish report: User behavior and human risk management*.
- Roer, K. (2022). *The security culture playbook: An executive guide to reducing risk and developing your human defense layer*. Wiley.
- Sarker, I. H., Kayes, A. S. M., Badsha, S., Alqahtani, H., Watters, P., & Ng, A. (2020). Cybersecurity data science: An overview from machine learning perspective. *Journal of Big Data, 7*(1), 1-29.